Scenario - Based Assessment

Q1) Footprinting Tools - Conducting competitive Intelligence

AIM:
To perform a passive security assessment of ABC Technologies using footprinting tools without directly Interacting with the company's servers.

Tools used:

Tool	Purpose
WHOIS	Retrieves domain registration details
theHarvester	collects employee email addresses and subdomains
Netcraft	Identifies web technologies and hosting details

Application of Each Tool

1. WHOIS

command
whois abctechnologies.com

Information collected

* Domain registration date
* Expiry date
* Registrar details
* Name servers
* organization Information

Role in competitive Intelligence

* Identifies domain ownership
* Reveals domain lifecycle Information
* Helps assess the organization's online presence.

2. theHarvester

command

the Harvester -d abctechnologies.com -b all

Information collected:

-> Employee email addresses
-> public subdomains
-> Hostnames
-> Ip address

Role in competitive Intelligence

* Identifies employee naming patterns
* Reveals public-facing Infrastructure
* supports security assessments

3. Netcraft

website

https://www.netcraft.com/

Information collected

* webserver
* operating system
* Hosting provider
* Technology stack
* SSL certificate Information

Role in competitive Intelligence.

* Identifies technologies used by the organization
* Helps understand Infrastructure and software platforms

Conclusion:

passive footprinting helps security professionals gather valuable public Information without directly Interacting with the target's systems. These tools assist in competitive Intelligence, asset discovery and identifying potential security risks.

2. DNS Zone Transfers

AIM:

To verify whether a DNS server allows unauthorized DNS zone Transfers (AXFER)

Introduction:

A DNS zone Transfer copies DNS records from a primary DNS server to a secondary server. If misconfigured, attackers can retrieve sensitive DNS information.

Command used:

Using Dig:

```
dig AXFR example.com @ns1.example.com
or
dig example.com AXFR
```

If zone Transfer succeeds.

The attacker may obtain:

* Internal hostnames
* Public subdomains
* Mail serves (mx records)
* Name servers.
* IP addresses
* DNS records.

Security Implications:

- → Map the orgnization's infrastructure.
- → Identify critical systems.
- → locate mail servers for phishing attacks
- → Discover hidden subdomains.
- → plan targeted attacks.

Recommendations:

-> Disable unauthorized zone transfers
-> Allow AXFER only for trusted secondary DNS servers
-> Use firewalls to restrict DNS accesses
-> Enable DNSSEC
-> Monitor DNS logs.
-> Regularly audit DNS configuration.

Conclusion:

Restricting DNS zone transfers prevents attackers from collecting valuable reconnaissance Information and strengthens the organization's DNS security.

3) Social Engineering Attacks and countermeasures.

Introduction:

Social engineering is the manipulation of individuals into revealing confidential Information or performing actions that compromise security.

Attacks Identification:

The attacker Impersonates the IT department and urges employees to verify their login credentials through a fake website.

How the Attack Works.

* The attacker sends a fake email
* The email appears to come from the IT department
* Employee click the provided link
* They enter their usernames and passwords
* The attacker steals the credentials.

3) How these countermeasure prevent Theft:

→ verify the sender prevents trust in spoofed emails

→ Inspecting links helps Identify fake website

→ confirming requests with IT avoids falling for Impersonation.

→ MFA blocks unauthorized access even if passwords are compromised.

→ Reporting suspicious emails helps protect other employees.

→ Regular awareness training Improves recognition of phishing attempts.

Conclusion:-

Phishing attacks exploit human trust rather than technical vulnerabilities. By following security best practic verifying and using MFA, employee can significantly reduce the risk of credential theft and other social engineering attacks.